APPLICATION SECURITY REVIEW

Acme Payments Portal

Version 2.7.0 (release candidate) | Merchant payments back office

Not approved

Release blocked. Re-test required after the Critical and High findings are closed.

Review ticket	ASR-2026-041
Application tier	Tier 1 (critical)
Data classification	Restricted (cardholder data, PII)
Product owner	Dana Whitfield (Head of Merchant Services)
Technical lead	Ravi Menon
Hosting	AWS eu-west-1 (ECS, RDS PostgreSQL, S3)
Technology	Python 3.12, SQLite (local) / PostgreSQL (prod), Docker
Review window	Requested 2026-09-08; testing 2026-09-15 to 2026-09-25; report issued 2026-09-29
Reviewer	AppSec Review Team (demo)
Method	Threat modelling, automated pipeline (secrets, SAST, SCA, IaC, container, DAST), manual code review and authenticated testing; OWASP ASVS 4.0.3 and OWASP Top 10 (2021).

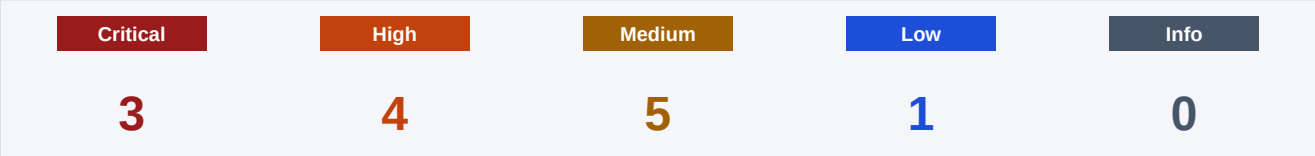
This is a demonstration document. The application, company, people and findings are fictional; the code excerpts and pipeline results are real output from the demo apps in this repository.

1. Executive summary

The Payments Portal lets merchant-services staff search transactions, download settlement exports and run network diagnostics. It processes merchant data and truncated card numbers and is classed Tier 1 (critical).

The review found **13 findings: 3 Critical, 4 High, 5 Medium and 1 Low**. Three of the Critical issues are directly exploitable by an unauthenticated attacker and give full database access, remote command execution on the container, or cloud account access through credentials committed to source. Authentication and authorisation are effectively absent: every endpoint, including `/admin`, is open.

The automated pipeline blocked the release on the same evidence (6 Critical and 8 High tool findings before consolidation), so manual and automated results agree. The portal should not be exposed to the internet until the Critical and High findings are fixed and re-tested.



Findings by severity (CVSS v3.1 base score)

Top risk drivers	Unauthenticated SQL injection and command injection; Cloud credentials committed to the repository; No authentication or role model; Public S3 bucket and world-open SSH
Pipeline gate	FAIL (expected: FAIL)
Decision	**Not approved**. Release blocked. Re-test required after the Critical and High findings are closed.
Re-test	Re-test requested after remediation. Target week of 2026-10-19.

Conditions of approval

- Do not expose the portal to the internet until a re-test passes.
- Rotate every credential that has ever appeared in the repository.
- A pipeline gate pass is required, with no waivers on Critical or High findings.

2. Scope and approach

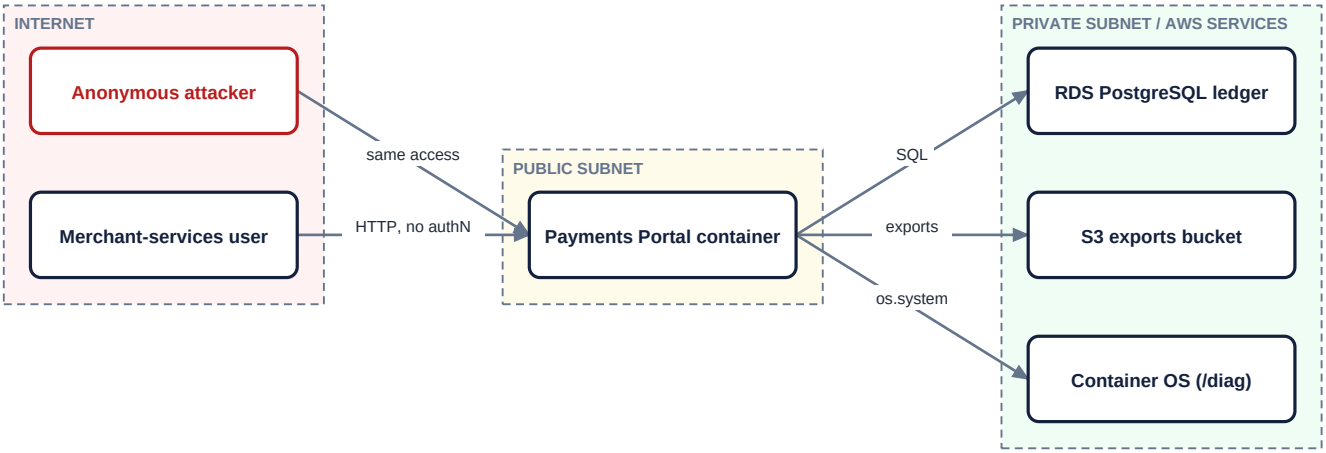
In scope

- Application source (app.py), 85 lines
- Dependency manifest and container build
- Terraform for S3, security group and RDS
- Dynamic testing of a staging instance (localhost-equivalent)

Out of scope

- AWS account-level guardrails (SCPs, org policy)
- Payment-scheme (PCI) assessment by the QSA
- Third-party acquirer API

3. Architecture and trust boundaries



Requests arrive over the internet to a single container. Search terms are concatenated into a SQL statement against the ledger; export file names are joined to a directory path and read from disk; the diagnostics route shells out. No component authenticates the caller.

Good practices observed

- Login route uses a parameterised query for the user lookup.
- Repository already runs the pipeline on every push, which is why the gate caught these issues before release.
- Truncated card numbers (last four digits) only; no full PAN is stored.

4. Threat model (STRIDE)

Threats were enumerated per trust boundary. 'Assessment' describes the control state found during the review.

Category	Threat	Existing control	Assessment	Findings
Spoofing	Anyone can call any route; session value is guessable	None	**Gap**	PAY-04, PAY-09
Tampering	SQL and command injection modify data and host state	None	**Gap**	PAY-01, PAY-02
Repudiation	No audit trail of searches, exports or diagnostics	None	**Gap**	PAY-13
Information disclosure	Hashes served at /admin, traversal reads files, verbose errors, public bucket	None	**Gap**	PAY-04, PAY-05, PAY-07, PAY-10
Denial of service	No rate limits; diagnostics route can be abused to spawn processes	None	**Gap**	PAY-13
Elevation of privilege	Command injection as root; committed cloud keys	None	**Gap**	PAY-02, PAY-03, PAY-11

5. Findings summary

ID	Finding	Severity	CVSS	Priority	Source	Due
PAY-01	SQL injection in transaction search	**Critical**	9.8	P0	Pipeline (SAST, DAST) + manual exploit	Before release
PAY-02	OS command injection in diagnostics route	**Critical**	9.8	P0	Pipeline (SAST) + manual	Before release
PAY-03	Cloud and signing credentials committed to source	**Critical**	9.9	P0	Pipeline (secret scan)	Immediately
PAY-04	No authentication or authorisation on any route	**High**	7.5	P0	Pipeline (DAST) + manual	Before release
PAY-05	Path traversal in settlement export download	**High**	7.5	P1	Pipeline (SAST, DAST)	Before release
PAY-06	Vulnerable dependencies pinned in requirements.txt	**High**	8.1	P1	Pipeline (SCA)	14 days
PAY-07	Cloud misconfiguration: public bucket, world-open SSH, unencrypted database	**High**	7.5	P0	Pipeline (IaC scan)	Before release
PAY-08	Unsalted MD5 password hashes	**Medium**	5.9	P1	Pipeline (SAST)	30 days
PAY-09	Predictable session value and missing cookie flags	**Medium**	6.8	P1	Pipeline (SAST) + manual	30 days
PAY-10	Exception text returned to the client	**Medium**	5.3	P2	Pipeline (SAST)	30 days
PAY-11	Container runs as root from an unpinned base image	**Medium**	5.3	P2	Pipeline (container scan)	30 days
PAY-12	Security response headers missing	**Low**	3.1	P3	Pipeline (DAST)	60 days
PAY-13	No audit logging or rate limiting for sensitive actions	**Medium**	5.3	P2	Manual review	60 days

Priority reflects business urgency and can exceed what CVSS alone implies (P0 fix now, P1 before release/go-live, P2 within 30 days, P3 backlog).

6. Detailed findings

PAY-01 SQL injection in transaction search	CRITICAL
CVSS	9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Classification	CWE-89 | A03:2021 Injection
Priority / owner / due	P0 | Ravi Menon | Before release
Detected by	Pipeline (SAST, DAST) + manual exploit (rules: SAST-SQLI, DAST-SQLI)
Description	The merchant search term is placed directly into a SQL string. A lone quote character produces a database error, and a crafted term can read any table, including the users table with password hashes.
Impact	Unauthenticated read of the entire ledger and user table; modification is possible with stacked or UPDATE-capable statements on production PostgreSQL.
Recommendation	Use a parameterised query: `DB.execute("... WHERE merchant LIKE ?", ("%" + term + "%",))`. Add an allow-list length limit on the term. Add a regression test that submits a quote and a boolean payload.

Evidence: apps/payments-portal/app.py line 29

```
28 | def search_payments(term):
29 |     query = f"SELECT id, merchant, amount FROM payments WHERE merchant LIKE '%{term}%'"
30 |     return [dict(zip(("id", "merchant", "amount"), row)) for row in DB.execute(query)]
```

PAY-02 OS command injection in diagnostics route	CRITICAL
CVSS	9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Classification	CWE-78 | A03:2021 Injection
Priority / owner / due	P0 | Ravi Menon | Before release
Detected by	Pipeline (SAST) + manual (rules: SAST-CMDI)
Description	The `host` query parameter is concatenated into a shell command, so shell metacharacters (for example a semicolon) run arbitrary commands as the container user, which is root.
Impact	Remote code execution on the container, access to the task role credentials, and a pivot into the VPC.
Recommendation	Remove the route if it is not needed. Otherwise call `subprocess.run(["nslookup", host])` with no shell, validate the host against a strict hostname pattern, and require an admin role.

Evidence: apps/payments-portal/app.py line 59

```
58 |             elif url.path == "/diag":
59 |                 os.system("nslookup " + args.get("host", "localhost"))
60 |                 self.reply(200, {"status": "done"})
```

PAY-03 Cloud and signing credentials committed to source	CRITICAL
CVSS	9.9 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H)
Classification	CWE-798 | A07:2021 Identification and Authentication Failures
Priority / owner / due	P0 | Ravi Menon | Immediately
Detected by	Pipeline (secret scan) (rules: SEC-AWS-ACCESS-KEY, SEC-AWS-SECRET, SEC-HARDCODED-SECRET)
Description	An AWS access key pair and the session signing secret are literals in app.py (values are the public documentation examples in this demo, and are redacted by the scanner). Anyone with read access to the repository, or to a built image, holds the credentials.
Impact	Cloud account access at the key's privilege level; forgery of session values using the known signing secret.
Recommendation	Revoke and rotate both secrets now, treat them as compromised, and purge them from git history. Use the ECS task role for AWS access and load the signing secret from AWS Secrets Manager. Add a pre-commit secret scan.

Evidence: apps/payments-portal/app.py line 14

```
13 | JWT_SECRET = "********"
14 | AWS_ACCESS_KEY_ID = "********"
15 | AWS_SECRET_ACCESS_KEY = "********"
```

PAY-04 No authentication or authorisation on any route	HIGH
CVSS	7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Classification	CWE-306 | A01:2021 Broken Access Control
Priority / owner / due	P0 | Dana Whitfield / Ravi Menon | Before release
Detected by	Pipeline (DAST) + manual (rules: DAST-UNAUTH-ACCESS)
Description	The /admin route returns every user with their password hash to an anonymous caller, and the other routes check no identity. The login route issues a cookie but nothing validates it.
Impact	Anonymous disclosure of user accounts and hashes; no accountability for any action.
Recommendation	Put the portal behind corporate SSO (OIDC) and enforce a deny-by-default authorisation check with a role (merchant_support, admin) on every route. Never return password hashes from any API.

Evidence: apps/payments-portal/app.py line 61

```
60 |                 self.reply(200, {"status": "done"})
61 |             elif url.path == "/admin":
62 |                 rows = DB.execute("SELECT id, name, pw_md5, role FROM users").fetchall()
```

PAY-05 Path traversal in settlement export download	HIGH
CVSS	7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Classification	CWE-22 | A01:2021 Broken Access Control
Priority / owner / due	P1 | Ravi Menon | Before release
Detected by	Pipeline (SAST, DAST) (rules: SAST-PATH-TRAVERSAL, DAST-PATH-TRAVERSAL)
Description	The file name is joined to the export directory without containment. Dynamic testing read /etc/passwd and the application source by supplying ../ sequences.
Impact	Disclosure of any file readable by the container user, including source, configuration and mounted secrets.
Recommendation	Map a short export id to a file through an allow-list, or resolve the path and reject anything outside the export directory (`os.path.commonpath`).

Evidence: apps/payments-portal/app.py line 33

```
32 |
33 | def read_export(name):
34 |     with open(os.path.join("exports", name), "rb") as handle:
```

PAY-06 Vulnerable dependencies pinned in requirements.txt	HIGH
CVSS	8.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)
Classification	CWE-1104 | A06:2021 Vulnerable and Outdated Components
Priority / owner / due	P1 | Ravi Menon | 14 days
Detected by	Pipeline (SCA) (rules: SCA-VULNERABLE-DEPENDENCY)
Description	PyYAML 5.3 (CVE-2020-14343, critical), requests 2.19.0 (CVE-2018-18074 high and CVE-2023-32681 medium) and Jinja2 2.10 (CVE-2019-10906, high) are pinned. Reachability: the current code does not import these packages, so exploitation needs a code change, which is why the vector uses high attack complexity. They still ship in the image.
Impact	Latent code-execution and credential-leak risk that becomes live the moment a developer uses the libraries.
Recommendation	Upgrade to PyYAML 6.0.2, requests 2.32.4 and Jinja2 3.1.6 or remove unused packages. Enable Dependabot and fail the build on new high advisories.

Evidence: apps/payments-portal/requirements.txt line 1

```
1 | PyYAML==5.3
2 | requests==2.19.0
```

PAY-07 Cloud misconfiguration: public bucket, world-open SSH, unencrypted database	HIGH
CVSS	7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Classification	CWE-732 | A05:2021 Security Misconfiguration
Priority / owner / due	P0 | Platform team | Before release
Detected by	Pipeline (IaC scan) (rules: IAC-S3-PUBLIC-ACL, IAC-SG-OPEN-ADMIN-PORT, IAC-RDS-UNENCRYPTED)
Description	The exports bucket has a public-read ACL, the security group allows SSH from 0.0.0.0/0, and the ledger database has storage_encrypted = false.
Impact	Settlement exports readable by anyone who finds the bucket name; SSH exposed to internet brute force; ledger data unencrypted at rest.
Recommendation	Remove the ACL and add aws_s3_bucket_public_access_block; replace SSH with SSM Session Manager or a VPN CIDR; recreate the database with storage_encrypted = true and a customer-managed KMS key.

Evidence: apps/payments-portal/infra/main.tf line 3

```
  2 |   bucket = "acme-payments-exports"
  3 |   acl    = "public-read"
  4 | }
```

PAY-08 Unsalted MD5 password hashes	MEDIUM
CVSS	5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N)
Classification	CWE-328 | A02:2021 Cryptographic Failures
Priority / owner / due	P1 | Ravi Menon | 30 days
Detected by	Pipeline (SAST) (rules: SAST-WEAK-HASH)
Description	Passwords are stored as unsalted MD5. Combined with PAY-04 (hashes are served to anonymous callers) the default admin password is recoverable in seconds.
Impact	Fast offline cracking of every account password.
Recommendation	Move to SSO. If local passwords remain, use argon2id or PBKDF2-HMAC-SHA256 (600,000+ iterations) with a per-user salt, and force a reset on next login.

Evidence: apps/payments-portal/app.py line 74

```
 73 |         creds = json.loads(self.rfile.read(size) or b"{}")
 74 |         digest = hashlib.md5(creds.get("password", "").encode()).hexdigest()
 75 |         row = DB.execute("SELECT id FROM users WHERE name = ? AND pw_md5 = ?", (creds.get("user"
```

PAY-09 Predictable session value and missing cookie flags	MEDIUM
CVSS	6.8 (CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N)
Classification	CWE-614 | A07:2021 Identification and Authentication Failures
Priority / owner / due	P1 | Ravi Menon | 30 days
Detected by	Pipeline (SAST) + manual (rules: SAST-COOKIE-FLAGS)
Description	The session cookie is the user id plus a fixed prefix of the signing secret, so it is guessable, and it lacks Secure, HttpOnly and SameSite attributes.
Impact	Session forgery and cookie theft over plain HTTP or through script injection.
Recommendation	Use a framework session with a random 128-bit identifier stored server-side, set Secure; HttpOnly; SameSite=Lax, rotate on login and expire after inactivity.

Evidence: apps/payments-portal/app.py line 78

```
 77 |             return self.reply(401, {"error": "invalid credentials"})
 78 |         self.reply(200, {"ok": True}, headers=[("Set-Cookie", "session=%s-%s; Path=/" % (row[0],
 79 |
```

PAY-10 Exception text returned to the client	MEDIUM
CVSS	5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Classification	CWE-209 | A05:2021 Security Misconfiguration
Priority / owner / due	P2 | Ravi Menon | 30 days
Detected by	Pipeline (SAST) (rules: SAST-VERBOSE-ERRORS)
Description	Unhandled exceptions return str(exc), which confirmed the SQL injection and discloses file paths.
Impact	Information disclosure that speeds up exploitation.
Recommendation	Return a generic message with a correlation id and log the detail server-side.

Evidence: apps/payments-portal/app.py line 67

```
66 |         except Exception as exc:  # noqa: BLE001 - deliberately leaks the error
67 |             self.reply(500, {"error": str(exc)})
68 |
```

PAY-11 Container runs as root from an unpinned base image	MEDIUM
CVSS	5.3 (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L)
Classification	CWE-250 | A05:2021 Security Misconfiguration
Priority / owner / due	P2 | Platform team | 30 days
Detected by	Pipeline (container scan) (rules: DOCKER-ROOT, DOCKER-LATEST, DOCKER-NO-HEALTHCHECK)
Description	The image uses python:latest, has no USER instruction (runs as root) and no HEALTHCHECK. With PAY-02 this turns command injection into root in the container.
Impact	Larger blast radius for any code-execution flaw; non-reproducible builds.
Recommendation	Pin python:3.12-slim by digest, add a non-root USER, add a HEALTHCHECK, and run with a read-only root filesystem.

Evidence: apps/payments-portal/Dockerfile line 1

```
1 | FROM python:latest
2 | WORKDIR /srv/app
```

PAY-12 Security response headers missing	LOW
CVSS	3.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)
Classification	CWE-693 | A05:2021 Security Misconfiguration
Priority / owner / due	P3 | Ravi Menon | 60 days
Detected by	Pipeline (DAST) (rules: DAST-MISSING-HEADERS)
Description	Responses carry no X-Content-Type-Options, X-Frame-Options or Content-Security-Policy headers.
Impact	Weaker browser-side defence in depth.
Recommendation	Add the headers centrally in the reply helper or at the load balancer.

Evidence: apps/payments-portal/app.py line 39

```
38 | class Handler(BaseHTTPRequestHandler):
39 |     def reply(self, code, body, ctype="application/json", headers=()):
40 |         data = body if isinstance(body, bytes) else json.dumps(body).encode()
```

PAY-13 No audit logging or rate limiting for sensitive actions	MEDIUM
CVSS	5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)
Classification	CWE-778 | A09:2021 Security Logging and Monitoring Failures
Priority / owner / due	P2 | Ravi Menon | 60 days
Detected by	Manual review
Description	Request logging is switched off and there is no record of who searched, downloaded or ran diagnostics. There is no throttling on login or search.
Impact	Abuse and data exfiltration would go undetected; no forensic trail for a payments system.
Recommendation	Emit structured audit events (user, action, object, result) to the central log pipeline, alert on bulk exports, and add per-user and per-IP rate limits.

Evidence: apps/payments-portal/app.py line 80

```
 79 |
 80 |     def log_message(self, *_):
 81 |         pass
```

7. OWASP ASVS 4.0.3 coverage

Each chapter was assessed at ASVS level 2 for the controls relevant to this application.

Chapter	Result	Notes
V1 Architecture	**Fail**	No trust boundaries or threat model before this review.
V2 Authentication	**Fail**	No real authentication; MD5 hashes.
V3 Session Management	**Fail**	Guessable value, missing flags.
V4 Access Control	**Fail**	No authorisation anywhere.
V5 Validation and Encoding	**Fail**	SQL, command and path injection.
V6 Stored Cryptography	**Fail**	MD5, hard-coded keys, unencrypted DB.
V7 Error Handling and Logging	**Fail**	Verbose errors, no audit log.
V8 Data Protection	**Partial**	Only last four card digits stored; exports public.
V9 Communications	**Partial**	TLS terminates at the load balancer; not verified end to end.
V10 Malicious Code	**Partial**	Secrets in source.
V11 Business Logic	**Partial**	No abuse-case limits.
V12 Files and Resources	**Fail**	Path traversal.
V13 API and Web Service	**Fail**	Unauthenticated administrative API.
V14 Configuration	**Fail**	Public bucket, root container, stale dependencies.

8. Automated pipeline evidence

The demo pipeline ran against this application (run 20261006-173842, commit 9a4fe57). Policy: Acme AppSec release gate (demo).

Stage	Result	Findings	What it checks
Inventory	**PASS**	0	Enumerate files, languages and manifests
Secret scan	**WARN**	3	Regex rules for keys, tokens and credentials (gitleaks-style)
SAST	**WARN**	7	AST rules for injection, crypto and misconfiguration (Semgrep/CodeQL-style)
Dependency scan	**WARN**	4	Pinned packages vs. advisory data (pip-audit/Dependabot-style)
IaC scan	**WARN**	3	Terraform misconfiguration (Checkov/tfsec-style)

Stage	Result	Findings	What it checks
Container scan	**WARN**	3	Dockerfile hygiene (Hadolint/Trivy-style)
SBOM	**PASS**	0	CycloneDX 1.5 bill of materials (Syft-style)
DAST	**WARN**	4	Starts the app and probes it over HTTP (ZAP-style)
Release gate	**FAIL**	0	Applies policy.json and dated waivers

Gate: FAIL. 6 critical finding(s); 8 high finding(s); 7 medium findings exceed the limit of 5

9. Remediation roadmap

When	Action
Immediately	Revoke and rotate the AWS key pair and signing secret; purge from history (PAY-03).
Before release	Fix PAY-01, PAY-02, PAY-04, PAY-05, PAY-07; add authentication and role checks.
14 days	Upgrade dependencies and enable Dependabot (PAY-06).
30 days	Replace password storage, harden sessions, container and error handling (PAY-08 to PAY-11).
60 days	Headers, audit logging and rate limiting (PAY-12, PAY-13).
On completion	Request a re-test; the pipeline gate must pass and AppSec re-verifies each Critical and High finding.

10. Sign-off

Role	Name	Decision / acknowledgement	Date
AppSec reviewer	AppSec Review Team (demo)	**Not approved**	2026-09-29
Product owner	Dana Whitfield	Acknowledged findings and roadmap	2026-09-29
Technical lead	Ravi Menon	Accepts remediation dates	2026-09-29
Risk acceptance	None recorded	No residual risk was formally accepted	-

Appendix: rating scales

CVSS v3.1 base score	Severity	Priority	Meaning
9.0 - 10.0	**Critical**	P0	Fix immediately; blocks release.
7.0 - 8.9	**High**	P0 / P1	Fix before release or go-live.
4.0 - 6.9	**Medium**	P1 / P2	Fix within 30 days (earlier when data is sensitive).
0.1 - 3.9	**Low**	P3	Backlog.
None	**Info**	P3	Observation or hardening advice.